

Rapport d'audit

Projet « veilleur » — moniteur de disponibilité Ticketmaster.fr (CDC v1.1)
Date : 25 juillet 2026 · Périmètre : commits e821923 à a26db09 · Dépôt :
github.com/Limse-11660/3

1. Synthèse

L'audit a porté sur l'intégralité du projet (code, sécurité, exploitation réelle, packaging, qualité des tests) après sa première revue corrective. Il a produit **26 constats** : **1 bloquant**, **11 majeurs**, **13 mineurs** et 1 vérification sans problème. **24 sont résolus** (23 corrigés en trois lots de correctifs validés un par un, 1 résolu par décision de l'exploitant : retrait d'un événement terminé) ; **1 recommandation reste ouverte**, à la main de l'exploitant (neutralisation de l'ancien moniteur encore présent sur la machine).

Après correctifs : **107 tests automatisés verts** (chaque correctif est couvert par un test qui échouerait sans lui), vérifications en conditions réelles concluantes, et moniteur opérationnel en tâche de fond (3 événements suivis). Verdict global : **projet conforme au cahier des charges v1.1 et apte à l'exploitation continue**, dans les limites assumées du §6.

2. Contexte et périmètre

Le projet « veilleur » implémente le cahier des charges v1.1 : surveillance périodique d'événements Ticketmaster.fr par requêtes HTTP directes exclusivement (sans navigateur, sans proxy, sans contournement de protections), détection des transitions « indisponible vers disponible » et notification par webhook Discord. Architecture : Python (requests, PyYAML), état persisté en JSON atomique, CLI (run / check-once / list / test-notify). L'audit couvre l'état du dépôt après la revue corrective initiale, soit 8 modules source et leur suite de tests.

3. Méthode

Audit multi-agents en deux phases : (1) cinq auditeurs indépendants, un par dimension — correction des correctifs récents, sécurité et secrets, exploitation réelle (système vivant), packaging et documentation, qualité des tests — chacun tenu de ne rapporter que des défauts démontrables avec scénario concret ; (2) contre-vérification adversariale de chaque constat par trois agents sceptiques chargés de le réfuter. La phase 2 a été interrompue par la limite d'utilisation du compte : les constats non contre-vérifiés par agents l'ont été manuellement, par relecture directe du code, avant toute correction. Les correctifs ont ensuite été appliqués en trois lots successifs, chacun validé explicitement par l'exploitant, testé, commité et sauvegardé sur GitHub.

4. Constats et résolutions

4.1 Sécurité et secrets

Réf.	Constat	Gravité	Résolution
S1	Fuite possible du jeton du webhook Discord dans les journaux : les exceptions réseau (requests) contiennent l'URL complète du webhook, journalisée telle quelle.	Majeur	Corrigé (lot 1, commit 1d3fd5a) : caviardage systématique « /api/webhooks/** » de tout texte d'erreur avant journalisation, avec test dédié.
S2	Mentions Discord déclenchables par du contenu distant : un libellé de catégorie piégé (« @everyone ») aurait pingé tout le serveur.	Majeur	Corrigé (lot 1) : allowed_mentions vide sur tous les messages sortants.
S3	Identifiant d'événement accepté hors du chemin d'URL (query string, fragment).	Mineur	Corrigé (lot 2, commit 1f71af8) : extraction limitée au chemin de l'URL.
S4	Forge de lignes de journal possible via les libellés distants (caractères de contrôle non filtrés).	Mineur	Corrigé (lot 1) : libellés réduits aux caractères imprimables et bornés à 200 caractères.
S5	Jeton de webhook (révoqué, HTTP 401) encore lisible en clair dans le document du cahier des charges sur le Bureau.	Mineur	Corrigé (25/07) : jeton caviardé dans le document.

4.2 Correction des correctifs précédents (régressions)

Réf.	Constat	Gravité	Résolution
R1	Garde « relevé vide » non bornée : un événement durablement vidé conservait son ancien état, et une vraie réouverture ultérieure n'aurait jamais été alertée.	Majeur	Corrigé (lot 2) : après 3 relevés vides consécutifs, le vide devient l'état de référence ; les retours de stock réalertent normalement.
R2	Titre d'embed Discord non borné : un libellé long faisait rejeter le message (HTTP 400), alerte perdue.	Mineur	Corrigé (lot 1) : titre tronqué à 256 caractères.
R3	Assainissement de l'état trop superficiel : une feuille non conforme dans l'état persisté mettait l'événement en échec permanent.	Mineur	Corrigé (lot 2) : validation en profondeur au chargement, entrée écartée et baseline refaite.
R4	Clé d'entrée non injective : un séparateur « » dans un filtre pouvait faire entrer en collision deux entrées distinctes.	Mineur	Corrigé (lot 2) : encodage JSON injectif de la clé.

4.3 Exploitation réelle

Réf.	Constat	Gravité	Résolution
E1	Levée de file d'attente silencieuse : au premier relevé réussi après une file (cas NFL, Céline Dion), la baseline s'établissait sans aucune notification — le moment le plus utile passait inaperçu.	Majeur	Corrigé (lot 2) : message « surveillance active » listant les catégories disponibles et les prix dès la première baseline contenant du disponible.
E2	Aucune protection contre la double instance : relancer le lanceur pendant l'exécution doublait le sondage et les notifications.	Majeur	Corrigé (lot 1) : verrou mono-instance ; la seconde instance s'arrête avec un message clair.
E3	Backoff jusqu'à 15 minutes sur un événement en file d'attente : retard de détection inacceptable à l'ouverture des ventes.	Majeur	Corrigé (lot 2) : erreur « file d'attente » dédiée, plafonnée à 300 s (1 requête / 5 min).
E4	Événement « Concert Pique-Nique Reims » relevé à 0 catégorie : cécité possible si le paramètre idtier ne convenait pas à l'événement.	Majeur	Résolu par décision de l'exploitant : l'événement était terminé (séance du 18/07/2026) ; retiré de la surveillance le 25/07.
E5	Un événement en échec permanent était invisible dans l'état persisté.	Mineur	Corrigé (lot 2) : trace « derniere_erreur » (motif, horodatage, échecs consécutifs), purgée au retour à la normale.
E6	Horodatage du dernier relevé gelé pendant la garde « relevé vide ».	Mineur	Corrigé (lot 2) : horodatage mis à jour dans toutes les branches.

Réf.	Constat	Gravité	Résolution
E7	Ancien moniteur (projet « cct bot ») toujours présent et réactivable sur la même machine, sur les mêmes événements : risque de double sondage et de doubles notifications.	Mineur	Recommandation ouverte, à la main de l'exploitant (projet déclaré abandonné : neutraliser son lanceur si souhaité).
E8	Vérifications de bon fonctionnement (progression des compteurs, cohérence de l'état, propreté du dépôt git) : aucun problème.	RAS	—

4.4 Packaging et documentation

Réf.	Constat	Gravité	Résolution
P1	Installation documentée incomplète : sans « pip install -e . », aucune commande du README ne fonctionnait sur une machine neuve.	Bloquant	Corrigé (lot 3, commit a26db09) : étape ajoutée et expliquée.
P2	Commandes du README visant le Python système au lieu de celui de l'environnement virtuel.	Majeur	Corrigé (lot 3) : toutes les commandes passent par .venv.
P3	Blocs de commandes balisés « bash » pour des commandes cmd.exe.	Mineur	Corrigé (lot 3) : blocs rebalisés « bat ».

4.5 Qualité des tests

Réf.	Constat	Gravité	Résolution
T1	Commandes run et check-once sans aucune couverture (prouvé par mutation).	Majeur	Corrigé (lot 3) : tests de bout en bout (config réelle, client simulé, état sur disque, libération du verrou).
T2	Assainissement profond de l'état non testé.	Majeur	Corrigé (lots 2-3) : cas des feuilles non conformes couvert.
T3	Distinction « baseline vide » / « baseline absente » non verrouillée par un test.	Majeur	Corrigé (lot 3) : test de non-régression dédié.
T4	Durabilité (fsync) du correctif d'écriture atomique non couverte.	Mineur	Corrigé (lot 3) : test espion sur os.fsync.
T5	Borne de description Discord jamais exercée par la suite de tests.	Mineur	Corrigé (lot 3) : cas « libellés très longs » ajouté.
T6	Test d'espacement des requêtes dépendant de l'horloge réelle (fragile).	Mineur	Corrigé (lot 3) : horloge simulée, test déterministe.

5. Vérifications après correctifs

- **Tests automatisés** : 107 verts (dont 20 ajoutés par l'audit) ; chaque correctif est couvert par un test qui échouerait sans lui.
- **Notification** : message de test reçu sur le canal Discord de l'exploitant ; caviardage du jeton vérifié dans les journaux.
- **Détection réelle** : Les Misérables suivi avec 67 catégories en baseline ; files d'attente Queue-it détectées sur NFL Paris Game et Céline Dion et resondées toutes les 5 minutes au plus.
- **Exploitation** : redémarrages validés en réel ; verrou mono-instance vérifié ; état et compteurs persistés et en progression continue.

6. Limites assumées et risques résiduels

- **Nombre de places** : l'API publique interrogée n'expose pas les quantités par catégorie ; les alertes l'indiquent honnêtement (« nombre non exposé par le site »). Les obtenir exigerait un navigateur, exclu par le cahier des charges (§2.1).
- **Requêtes conditionnelles** : le site n'émet ni ETag ni Last-Modified (constaté le 24/07) ; le mécanisme 304 est implémenté et testé mais restera inactif tant que le site n'émet pas de validateurs.
- **Files d'attente** : jamais contournées, par principe ; la détection reprend à la levée de la file (délai maximal de 5 minutes).
- **Recommandation ouverte (E7)** : neutraliser le lanceur de l'ancien moniteur pour exclure tout double sondage accidentel.

7. État d'exploitation à la date du rapport

Le veilleur fonctionne en tâche de fond invisible (pythonw), démarre automatiquement à l'ouverture de session Windows (raccourci « veilleur-tm », désinstallable en un clic), journalise dans un fichier rotatif (veilleur.log, 2 Mo × 3) et surveille 3 événements : Les Misérables — Châtelet (67 catégories), NFL Paris Game et Céline Dion (en file d'attente). Le code est sauvegardé sur GitHub (9 commits, dépôt privé Limse-11660/3) ; les secrets (webhook, état, journaux) sont exclus du dépôt. Cette étape d'autonomie (journal fichier, démarrage automatique — commit ede30d1) a été réalisée après l'audit, en complément.